UNIVERSIDAD TECNOLOGICA DE TEHUACAN

PROGRAMA EDUCATIVO EN:

Tecnologías de la Información en Área Desarrollo
de Software Multiplataforma

NOMBRE DEL PROFESOR:

José Miguel Carrera Pacheco

NOMBRE DEL ESTUDIANTE:

Ciro Julian Cervantes Zamora

MATERIA:

Desarrollo Web Profesional

TEMA:

Login seguro

TEHUACÁN, PUEBLA, ENERO-ABRIL 2026

Arquitectura del login: JWT

Se decidió utilizar JSON Web Tokens (JWT) como mecanismo de autenticación. Esto se debe a que el proyecto tiene arquitectura separada entre frontend y backend, lo que hace que JWT sea más adecuado al no requerir estado en el servidor.

El token debe cumplir con:

- Algoritmo de firma: HS256.
- Tiempo de expiración: 8 horas.
- Payload: únicamente ID del usuario y su rol.
- Secret key almacenado en variable de entorno, nunca en el código fuente.

Manejo de roles

Se definen dos roles en el sistema:

Comprador: usuario público, no requiere autenticación. Puede buscar productos, comparar precios y ver información de tiendas.

Tienda: usuario autenticado. Puede iniciar sesión, acceder a su panel y modificar únicamente la información de su propio negocio.

El backend valida el rol incluido en el JWT antes de permitir cualquier acción de escritura. Si el rol no tiene permisos sobre esa ruta, se devuelve error 403.

Reglas para el diseño del formulario de login

El formulario de inicio de sesión debe diseñarse siguiendo principios de seguridad, accesibilidad y usabilidad.
El objetivo es garantizar que el acceso al sistema sea seguro sin afectar la experiencia del usuario.

El login debe ser:

- Seguro, para evitar accesos no autorizados.
- Accesible, para permitir el uso por cualquier persona.
- Controlado por teclado, sin depender del mouse.
- Claro, mostrando errores comprensibles.
- Profesional, siguiendo buenas prácticas de desarrollo.

Definir estas reglas desde la fase de diseño permite evitar problemas durante la implementación.

Comportamiento de un formulario accesible

Un formulario accesible debe permitir que el usuario pueda iniciar sesión utilizando únicamente el teclado o tecnologías asistidas.

El formulario debe cumplir con las siguientes reglas:

- Permitir navegar entre campos usando la tecla Tab.
- Permitir enviar el formulario usando la tecla Enter.
- Tener etiquetas visibles asociadas a cada campo.
- Mostrar mensajes de error sin borrar la información ingresada.
- Indicar claramente qué campo contiene un error.
- Mantener el foco dentro del formulario cuando ocurre un error.
- Usar atributos accesibles como aria-invalid y aria-live cuando sea necesario.

Estas características garantizan que el sistema pueda ser utilizado por todos los usuarios.

Errores comunes en formularios de login

Durante el desarrollo de formularios de autenticación pueden ocurrir errores que afectan la seguridad o la experiencia del usuario.

Algunos errores comunes son:

- Mostrar mensajes que revelan si el usuario existe.
- No validar datos en el servidor.
- Permitir enviar el formulario vacío.
- No permitir el uso del teclado.
- Borrar los campos cuando ocurre un error.
- No limitar el acceso por rol.
- No proteger rutas privadas.

Evitar estos errores es necesario para implementar un login seguro y profesional.

Manejo seguro de errores de autenticación

El sistema no debe mostrar mensajes que expongan información sensible.

Ejemplos incorrectos:

- "El usuario no existe"
- "Contraseña incorrecta"
- "Correo no registrado"

Ejemplo correcto:

- "Credenciales inválidas"

Mostrar mensajes genéricos evita que personas no autorizadas puedan descubrir cuentas registradas en el sistema.

Los errores deben mostrarse de forma clara, pero sin revelar detalles internos del sistema.

Manejo seguro de sesiones

El sistema debe controlar el acceso mediante un proceso de autenticación seguro.

El manejo de sesión debe cumplir con:

- Validar credenciales en el servidor.
- Crear una sesión o token después del login.
- Verificar la sesión en cada petición.
- Validar el rol del usuario antes de permitir acciones.
- Impedir el acceso si no existe sesión válida.
- Limitar los permisos según el rol.

Esto permite que solo usuarios autorizados puedan modificar información.

Control por teclado en el login

El formulario de login debe poder utilizarse completamente sin mouse.

El sistema debe permitir:

- Navegación con Tab entre campos.
- Activar botones con Enter.
- Ver claramente el campo seleccionado.
- Mostrar errores sin perder el foco.

Esto mejora la accesibilidad y cumple con buenas prácticas de desarrollo web.

Validaciones concretas del formulario

Campo correo electrónico:

- Obligatorio, no puede enviarse vacío.
- Debe tener formato válido (usuario@dominio.com).
- Sin espacios, máximo 255 caracteres.

Campo contraseña:

- Obligatorio, mínimo 8 caracteres, máximo 128.
- Se muestra enmascarado.
- No se limpia si ocurre un error.

Las validaciones se aplican tanto en frontend como en backend.

Actualización de issues para implementación futura

- Implementar login accesible controlado por teclado
- Implementar validaciones accesibles en frontend
- Implementar mensajes de error seguros
- Implementar sesión segura en backend
- Implementar control de roles
- Implementar middleware de autenticación
- Agregar tests del login
- Verificar accesibilidad del formulario